

Estado de revisión: Borrador de traducción asistida por máquina. Requiere revisión humana de terminología, significado, enlaces, formato y vigencia técnica antes de marcarse como edición final.

NIST RISK MANAGEMENT FRAMEWORK

Y SP 800-53 RELEASE 5.2.0

Manual de Gestor Práctica y Analista Junior

TEN **Lo que este manual hace:** Explica los siete pasos RMF, las 20 familias de control SP 800-53, bases de referencia, configuración, implementación, evaluación, autorización, monitoreo, OSCAL, herramientas de código abierto, decisiones de gestión y trabajo analista de trabajo. | |.

Alberto (Al) Leiva

Primera edición • Julio 2026

Prefacio

El Marco de Gestión de Riesgos es una forma disciplinada de conectar las necesidades de las misiones, el diseño del sistema, la seguridad, la privacidad, las pruebas y las decisiones de riesgo responsables a lo largo de un ciclo de vida del sistema. SP 800-53 es el catálogo de control utilizado dentro de ese proceso; no es una lista de verificación que automáticamente crea seguridad o una autorización.

Este manual utiliza lenguaje claro, documentos de trabajo realistas y laboratorios seguros. Se explican términos federales, pero las organizaciones no federales pueden adaptar los conceptos. Los requisitos y la autoridad varían por ley, agencia, contrato, sector, sistema y riesgo. Utilizar fuentes oficiales actuales y seguridad calificada, privacidad, ingeniería, legal, adquisición, auditoría y autorizar a profesionales para decisiones reales.

**** Nota de información actual:** ** Verified July 14, 2026: SP 800-37 Rev. 2 remains the current final RMF; SP 800-53 and SP 800-53A are at Release 5.2.0 (August 2025); SP 800-53B baselines were reissued without baseline changes; SP 800-18 Rev. 2 was finalized June 30, 2026. |

|.

Cómo usar este manual

- Gerentes: comiencen con los Capítulos 1–4, 7–13, 17–18 y 27.
- Analistas junior: estudiar en orden, practicar Capítulos 26 y 28–29, y utilizar las plantillas.
- Propietarios e ingenieros de sistemas: enfoque en los límites, selección, implementación, evidencia, monitoreo y capítulos familiares.
- Evaluadores: enfoque en los capítulos 10, 15-18, 25 y 30.

- Adaptar cada artefacto a la autoridad de la organización, tolerancia al riesgo, sistema y obligaciones.

Tabla de contenidos

Este documento contiene una tabla de contenidos de Word nativa y una guía de capítulo permanente.

[Prefacio \[2\] \(#preface\)](#)

[Cómo utilizar este manual \[2\] \(#how-to-use-this-manual\)](#)

[Tabla de contenidos \[3\] \(#table-of-contents\)](#)

[Guía de cambio \[7\]\(#chapter-guide\)](#)

[1. RMF y SP 800-53 Foundations \[8\]\(#rmf-and-sp-800-53-foundations\)](#)

[2. Actual NIST Publication Suite \[9\]\(#current-nist-publication-suite\)](#)

[3. Gobernanza, Funciones y Decisiones de Riesgo \[10\]\(#governance-roles-and-risk-decisions\)](#)

[4. Ciclo de vida del sistema, alcance y autorización de límites \[11\]\(#system-life-cycle-scope-and-authorization-boundary\)](#)

[4.1 Preguntas beniarías \[11\]\(#boundary-questions\)](#)

[5. Prepare at the Organization Level \[12\]\(#prepare-at-the-organization-level\)](#)

[5.1 Preparación de las organizaciones \[12\]\(#organization-preparation\)](#)

[6. Prepare at the System Level \[13\]\(#prepare-at-the-system-level\)](#)

[6.1 Preparación del sistema \[13\]\(#system-preparation\)](#)

[7. Categorizar el sistema \[14\]\(#categorize-the-system\)](#)

[7.1 Método \[14\]\(#method\)](#)

[8. Select Controls \[15\]\(#select-controls\)](#)

[8.1 Secuencia de selección \[15\]\(#selection-sequence\)](#)

[9. Implement Controles \[16\]\(#implement-controls\)](#)

[9.1 Flujo de trabajo de aplicación \[16\]\(#implementation-workflow\)](#)

[10. Controles de Evaluación \[17\]\(#assess-controls\)](#)

[10.1 Secuencia de evaluación \[17\]\(#assessment-sequence\)](#)

[11. Autorizar el Sistema o Controles Comunes \[18\]\(#authorize-the-system-or-common-controls\)](#)

[11.1 Paquete de autorización \[18\]\(#authorization-package\)](#)

12. Monitor continuo [19](#monitor-continuously)

12.1 Actividades de vigilancia [19](#monitoring-activities)

13. Bases de control y Adaptación [20](#control-baselines-and-tailoring)

13.1 Grabación de Tailoring [20](#tailoring-record)

14. Controles comunes, híbridos y sistémicos [21](#common-hybrid-and-system-specific-controls)

14.1 Verificación de la herencia [21](#inheritance-checks)

15. Redacción de declaraciones de aplicación firme [22](#writing-strong-implementation-statements)

15.1 Lista de comprobación de cuentas [22](#statement-checklist)

16. Assessment Planning and Evidence [23](#assessment-planning-and-evidence)

16.1 Población y muestreo [23](#population-and-sampling)

17. Paquete de Autorización y POA plagaM [24](#authorization-package-and-poam)

17.1 POA comuniónM quality [24](#poam-quality)

[18. Estrategia de vigilancia continua [25] (#continuous-monitoring-strategy)] (#continuous-monitoring-strategy)

19. OSCAL and Automation [26](#oscal-and-automation)

19.1 Salvaguardias de automatización [26](#automation-safeguards)

20. Familias de control: acceso, conciencia, auditoría y evaluación [27](#control-families-access-awareness-audit-and-assessment)

AC — Access Control [27](#ac-access-control)

AT — Conciencia y capacitación [27](#at-awareness-and-training)

AU — Audit and Accountability [27](#au-audit-and-accountability)

CA — Assessment, Authorization, and Monitoring [27](#ca-assessment-authorization-and-monitoring)

21. Familias de control: Configuración, Contingencia, Identidad, Incidencia y Mantenimiento [28](#control-families-configuration-contingency-identity-incident-and-maintenance)

CM — Configuration Management [28](#cm-configuration-management)

CP — Contingency Planning [28](#cp-contingency-planning)

IA — Identificación y autenticación [28](#ia-identification-and-authentication)

IR — Respuesta de incidentes [28](#ir-incident-response)

MA — Maintenance [28](#ma-maintenance)

22. Familias de control: Medios, Física, Planificación, Programa y Personal [30](#control-families-media-physical-planning-program-and-personnel)

MP — Media Protection [30](#mp-media-protection)

PE — Protección física y ambiental [30](#pe-physical-and-environmental-protection)

PL — Planning [30](#pl-planning)

PM — Gestión de programas [30](#pm-program-management)

PS — Personnel Security [30](#ps-personnel-security)

23. Familias de control: Privacidad, Riesgo, Adquisición, Comunicaciones, Integridad y Cadena de Suministros [32](#control-families-privacy-risk-acquisition-communications-integrity-and-supply-chain)

PT — PII Processing and Transparency [32](#pt-pii-processing-and-transparency)

RA — Risk Assessment [32](#ra-risk-assessment)

SA — Adquisición de sistemas y servicios [32](#sa-system-and-services-acquisition)

SC — System and Communications Protection [32](#sc-system-and-communications-protection)

SI — System and Information Integrity [32](#si-system-and-information-integrity)

SR — Supply Chain Risk Management [33](#sr-supply-chain-risk-management)

24. Riesgo de privacidad y colaboración de seguridad–Privacidad [34](#privacy-risk-and-securityprivacy-collaboration)

24.1 Colaboración [34](#collaboration)

25. Actualizaciones de software, fiabilidad de parche y liberación 5.2.0 [35](#software-updates-patch-reliability-and-release-5.2.0)

25.1 Evidencia [35](#evidence-focus)

26. Herramientas de código abierto y recursos oficiales [36](#open-source-tools-and-official-resources)

26.1 NIST CPRT [36](#nist-cprt)

26.2 NIST OSCAL Content [36](#nist-oscal-content)

26.3 Compliance Trestle [37](#compliance-trestle)

26.4 Lula [37](#lula)

26.5 CISO Assistant [37](#ciso-assistant)

26.6 Heimdall [37](#heimdall)

26.7 OpenControl [37](#opencontrol)

26.8 OSCAL CLI [38](#oscal-cli)

26.9 Wazuh [38](#wazuh)

26.10 OpenSCAP [38](#openscap)

26.11 osquery [38](#osquery)

26.12 Nmap [38](#nmap)

26.13 Greenbone Community Edition [39](#greenbone-community-edition)

26.14 Trivy [39](#trivy)

26.15 OWASP ZAP [39](#owasp-zap)

26.16 Keycloak [39](#keycloak)

26.17 DefectDojo [40](#defectdojo)

26.18 Agente de política abierta [40](#open-policy-agent)

27. Manual de juegos RMF [41](#managers-rmf-playbook)

27.1 Ritmo de administrador [41](#manager-rhythm)

28. Guía de la carrera de analista junior [42](#junior-analyst-career-guide)

28.1 Funciones comunes [42](#common-roles)

28.2 Trabajo típico [42](#typical-work)

29. Laboratorio Ficcional, Plan de Treinta Días y Preparación de Entrevistas [44](#fictional-laboratory-thirty-day-plan-and-interview-preparation)

29.1 Laboratorio de cartera [44](#portfolio-lab)

29.2 Plan de 30 días [44](#thirty-day-plan)

29.3 ¿Qué es RMF? [44](#what-is-rmf)

29.4 ¿Es SP 800-53 una lista de verificación? [45](#is-sp-800-53-a-checklist)

29.5 ¿Qué es una línea de referencia? [45](#what-is-a-baseline)

29.6 ¿Qué está adaptando? [45](#what-is-tailoring)

29.7 ¿Qué es la herencia de control? [45](#what-is-control-inheritance)

29.8 ¿Cómo evalúa un control? [45](#how-do-you-assess-a-control)

29.9 ¿Qué es la autorización? [45](#what-is-authorization)

- 29.10 ¿Qué es un POA cosechaM? [45](#what-is-a-poam)
- 29.11 ¿Qué es OSCAL? [45](#what-is-oscal)
- 29.12 ¿Qué es el SP 800-53 actual? [45](#what-is-current-sp-800-53)
30. Plantillas, Glosario, Índice y Referencias [46](#templates-glossary-index-and-references)
- 30.1 Registro de sistemas y límites [46](#system-and-boundary-record)
- 30.2 Documento de trabajo sobre la aplicación del control [46](#control-implementation-workpaper)
- 30.3 Assessment and finding record [46](#assessment-and-finding-record)
- 30.4 Registro de autorización y vigilancia [46](#authorization-and-monitoring-record)
- 30.5 Glosario [47](#glossary)
- 30.6 Índice de asunto [47](#subject-index)
- 30.7 Referencias oficiales [47](#official-references)

Guía del Capítulo

Capítulo

- 1
- 2
- 3
- 4
- 5
- 6
- 7
- 8
- 9
- 10 TERRITORIO Assess Controls
- 11
- 12 Silencioso Monitor
- 13 Silenciosos Bases de control y Tailoring
- TEN 14
- 15
- 16 Silencioso Evaluación Planificación y pruebas
- 17 Silencioso paquete de autorización y POA consigoM
- 18
- 19 Silencioso OSCAL y Automatización

Capítulo

TEN 20

TEN 21

TEN 22

TEN 23

24

TEN 25 TENIDOS Actualizaciones de software, Confiabilidad de parche y liberación 5.2.0 TEN 34

26

27 Silencioso Gerente de juegos RMF

28

29

30 TENIDOS Plantillas, Glosario, Índice y Referencias

1. RMF and SP 800-53 Foundations

RMF gestiona el riesgo de seguridad y privacidad mediante decisiones responsables del ciclo de vida.

■img src="media/image1.png" estilo="width:6.15in;height:3.39605in" alt="Prepare soporta cada paso, y Monitor alimenta nueva información de nuevo en las decisiones de riesgo."

Figura 1. Siete pasos RMF

Item | Purpose | | | RMF | Proceso para la gestión de riesgos de organización y sistema | SP 800-53 | Catálogo flexible de seguridad y control de privacidad | Una lista de verificación universal o línea de referencia – SP 800-53B TEN FOF Federal de bajos, moderados, altos y de privacidad, además de la orientación a medida | Un control a medida final establecido | SP 800-53A | Método de evaluación y procedimientos | Autorización | La decisión de riesgo del funcionario superior basado en un paquete de pruebas | Declaración de que ningún riesgo sigue siendo – Monitorización continua | Sensibilización de controles, cambios y riesgo | Un tablero sin acción de decisión |

Core idea: Los controles reducen el riesgo sólo cuando están correctamente seleccionados, implementados, operados, evaluados, corregidos y supervisados en el contexto del sistema real.

|

|. |

2. Actual NIST Publication Suite

Utilice la fuente oficial actual y entienda cómo cada publicación apoya el conjunto.

Publicación/recurso |

|... | tención SP 800-37 Rev. 2 | Siete pasos RMF tareas, roles, preparación de la organización/sistema y gestión del riesgo del ciclo de vida | SP 800-53 Release 5.2.0 | Actual catálogo de seguridad y control de privacidad, incluyendo 2025 actualización de software y cambios de parche – | SP 800-53A Release 5.2.0 | Procedimientos de evaluación actuales correspondientes a la versión 5.2.0 tención SP 800-53B Release 5.2.0 TEN Federal low/moderate/high and privacy baselines; 2025 reissue made no baseline changes | | SP 800-18 Rev. 2 | junio 2026 seguridad del sistema, privacidad y elementos del plan C-SCRM; énfasis legible por máquina – tención SP 800-30 Rev. 1 tención SP 800-39 | Gestión de riesgos a nivel de toda la Organización en tres niveles TEN CPRT Ø Navegador y descargas para controles actuales, bases de referencia, procedimientos y referencias | rígida OSCAL | Modelos legibles para catálogos, perfiles, componentes, SSPs, evaluaciones y POA plagas

- Control de la versión* Grabar la publicación, publicación, formato, fecha de recuperación, versión perfil/baseline y configuración local. Nunca mezclar texto, procedimientos y bases de control de diferentes versiones sin análisis. | Respuesta

3. Gobernanza, Funciones y Decisiones de Riesgo

RMF roles separados implementación, evaluación, propiedad y aceptación de riesgos.

■img src="media/image2.png" estilo="width:6.15in;height:3.39605in" alt="Enterprise direction, mission/business needs, and system controls must stay connected." /

Gráfico 2 Tres niveles de gestión de riesgos

Rol Silencioso** |

|... | | Jefe de agencia / organización tención Responsabilidad en toda la Organización y gobernanza del riesgo | Silencioso ejecutivo (función) | Autorización oficial | Acepta el sistema/common-control de riesgo o impone la autorización de condiciones/denas tención Autorización oficial designada representante designado | Coordina las actividades como delegadas; no hereda autoridad de riesgo no agranada Propietario del sistema Silencioso Misión del sistema, recursos, planes, controles, paquete y operación | Propietario de información / administrador | Requisitos de información, impacto, uso, compartir y protección TEN Seguridad / oficiales de privacidad | Requisitos del programa, asesoramiento, supervisión y coordinación Silencioso Proveedor de control | Implementa y documenta controles comunes, híbridos o específicos del sistema Silencioso asesor de control | Planes y realiza una evaluación objetiva; reporta resultados y límites TEN System administrador / ingeniero | Builds, configura, opera, monitorea y corrige las capacidades del sistema | TEN Enterprise architect / mission owner | Aligns systems, processes, dependencies, and organization architecture |

4. Ciclo de vida del sistema, alcance y autorización

Un límite claro es la base para la categorización, los controles, la evaluación y la autorización.

4.1 Preguntas sobre los resultados

- ¿Qué misión o función de negocio apoya el sistema?

- ¿Qué personas, procesos, aplicaciones, servicios, dispositivos, redes, datos, interfaces, ubicaciones, recursos en la nube, tecnología operativa y proveedores pertenecen dentro?
- ¿Qué hay fuera, pero está conectado, heredado, confiado o gestionado a través de un acuerdo?
- ¿Dónde hay límites de confianza, límites de autorización, flujos de datos, vías administrativas y servicios externos?
- ¿Quién posee cada componente y controla la responsabilidad?
- ¿Qué cambios requieren recategorización, reelección, reevaluación o revisión de autorización?

Edificio literario |

|... | | descripción del sistema | Propósito, usuarios, medio ambiente, estado de funcionamiento, tecnologías, dependencias | – Arquitectura diagrama tención Componentes, zonas, interfaces, límites de confianza, caminos de gestión | Flujo de datos ANTERI Tipos de información, fuentes, destinos, procesamiento, almacenamiento, compartir, eliminación | – Inventario | Hardware, software, firmware, recursos virtuales / cercanos, propietarios, versiones – Acuerdo de interconexión tención Sistemas, datos, controles, responsabilidades, monitoreo, incidentes y rescisión | Asignación de control | Común, híbrido, específico del sistema, heredado, proveedor, responsabilidades del cliente

5. Prepararse a nivel de organización
 - Preparación a nivel de organización hace que el sistema RMF funcione de manera coherente y eficiente.*

5.1 Organization preparation

- Establecer funciones de gestión del riesgo, estrategia, tolerancia al riesgo, prioridades y comunicación.
- Determinar las misiones, los procesos institucionales, las necesidades jurídicas, políticas y contratos, los interesados y los activos críticos.
- Desarrollar arquitectura empresarial, arquitectura de seguridad/privacy, controles comunes, requisitos para toda la organización y estrategia de vigilancia.
- Establecer orientaciones de impacto, normas de ajuste de base, valores de parámetro, superposiciones, expectativas de evaluación y enfoque de autorización.
- Determinar los riesgos de la cadena de suministro, los proveedores externos, las amenazas, los supuestos y las dependencias de toda la organización.
- Crear repositorios, automatización, plantillas, estándares de evidencia, revisión de calidad, métricas y procesos de mejora.

tención **Principio de eficiencia** Los controles comunes reutilizables, los parámetros aprobados, las pruebas estándar y el contenido legible por máquina reducen el trabajo repetido del sistema solo cuando la propiedad y las pruebas operativas actuales son fiables. | |.

6. Prepárate en el nivel del sistema

La preparación a nivel de sistemas define la misión específica, los interesados, los límites, la información y el enfoque.

6.1 Preparación del sistema

- Determinar el propósito de la misión/empresa, el propietario del sistema, autorizando oficiales, oficiales de seguridad/privacy, asesores, proveedores, usuarios e interesados directos.
- Definir el límite de autorización, elementos del sistema, entorno operativo, dependencias, interfaces, servicios externos y cadena de suministro.
- Identificar tipos de información, fines de procesamiento, riesgos de privacidad, flujos de datos y requisitos legales/contractuales.
- Determinar la etapa del ciclo de vida, el enfoque de desarrollo y adquisición, la arquitectura, las necesidades de ingeniería y la estrategia de autorización planificada.
- Registrar el sistema; identificar la herencia de control común y los recursos proporcionados por organizaciones.
- Hipótesis de documentos, limitaciones, riesgos, decisiones requeridas y calendario de paquetes.

7. Categorizar el sistema

Categorization describes the potential impact of the loss of confidentiality, integrity, or availability.

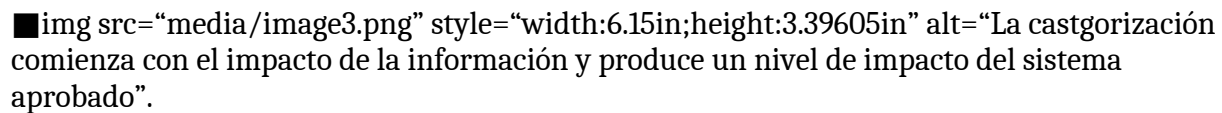
■  `img src="media/image3.png" style="width:6.15in;height:3.39605in" alt="La categorización comienza con el impacto de la información y produce un nivel de impacto del sistema aprobado".`

Gráfico 3

7.1 Method

- Identificar todos los tipos de información procesados, almacenados o transmitidos.
- Asignar impacto potencial —bajo, moderado o alto— para la confidencialidad, integridad y disponibilidad utilizando la orientación y el contexto de la misión aplicables.

- Aplicar el concepto de alta marca de agua para la categoría de seguridad del sistema, luego examinar si la agregación, las dependencias, la privacidad, la seguridad o los efectos de la misión justifican el ajuste bajo autoridad.
- Racionalidad de documentos, suposiciones, partes afectadas y aprobación.
- Revisita cuando la misión, los datos, la arquitectura, el medio ambiente, los usuarios, los proveedores o las amenazas cambian materialmente.

Advertencia de la categórica: Una categoría de alto impacto no significa que los controles sean débiles, y una categoría de bajo impacto no significa que el sistema sea seguro. Expresa daño potencial si se pierden los objetivos de seguridad. |

Respuesta

8. Seleccione Controles

Selection crea un conjunto de controles adaptados que abordan el sistema y el riesgo organizativo.

8.1 secuencia de selección

- Elija el perfil inicial definido por la organización o la base de referencia.
- Aplicar consideraciones de análisis e identificar controles que sean aplicables, no aplicables, heredados, híbridos o específicos del sistema.
- Asignar parámetros definidos por la organización como frecuencias, períodos de tiempo, roles, tecnologías y umbrales.
- Agregar controles o mejoras para la amenaza, misión, privacidad, cadena de suministro, ley, política, contrato, arquitectura o riesgo.
- Usar controles compensatorios únicamente mediante equivalencia aprobada y racionalidad documentada.
- Elaborar enfoques de supervisión y evaluación; determinar la responsabilidad y las pruebas de la aplicación.
- Documentar el conjunto, la racionalidad, las dependencias, los controles comunes y el riesgo residual.
- La selección de control no es la aplicación** Seleccionar AC-2 no crea gestión de cuentas. El sistema debe definir y operar a las personas, procesos, tecnología, pruebas y monitoreo necesarios para cada requisito seleccionado. | |.

9. Controles de aplicación

La implementación convierte los controles seleccionados en salvaguardias reales, asignadas, configuradas y operadas.

9.1 Implementation workflow

- Parse each control statement, enhancement, parameter, supplemental guidance, related controls, and allocation.
- Traducir requisitos en tareas de arquitectura, procedimientos, configuraciones, automatización, capacitación, contratos y funcionamiento.
- Assign accountable control owner and responsible implementers; identify hereed and shared portions.
- Definir la población, frecuencia, disparador, aprobación, excepción, registro, revisión, métrica y evidencia.
- Construir y probar a través del ciclo de vida del desarrollo del sistema; utilizar configuración y gestión del cambio.
- Escribir una declaración de implementación precisa que explica quién hace qué, dónde, cuándo, con qué configuración y evidencia.
- Correcciones de diseño o operación correctas antes de la evaluación formal cuando sea posible.

10. Evaluar los controles

La evaluación determina si los controles se aplican correctamente, funcionan según lo previsto y producen el resultado deseado.

10.1 Evaluación secuencia

- Determinar la independencia del evaluador y las calificaciones apropiadas para el riesgo.
- Elaborar y aprobar un plan de evaluación con alcance, controles, procedimientos, métodos, objetos, profundidad, cobertura, calendario, reglas, pruebas, muestreo y seguridad.
- Validar el límite del sistema, el sistema de control, la implementación, las poblaciones, los controles heredados y la confiabilidad de la fuente.
- Usar métodos de examen, entrevista y prueba; la investigación por sí sola suele proporcionar evidencia débil.
- Registro de resultados satisfechos u otros satisfactorios con pruebas, excepciones, limitaciones y riesgo.

- Permitir a los funcionarios responsables corregir las conclusiones; revocar las correcciones independientemente.
- Publicar un informe de evaluación que apoye la decisión del funcionario autorizado sin ocultar incertidumbre.

La evaluación no es un escaneo** Los resultados automatizados pueden probar condiciones importantes a escala, pero la evaluación también requiere criterios, alcance, población, diseño, contexto operativo, revisión humana, limitaciones y análisis de riesgos. | |

11. Autorizar el sistema o los controles comunes

- La apropiación es una decisión explícita de alto riesgo basada en el conjunto de medidas y el contexto organizativo*.

■img src="media/image4.png" style="width:6.15in;height:3.39605in" alt="El paquete es compatible con una decisión responsable con alcance definido, condiciones, duración y monitoreo".

Figure 7. Authorization risk decision

11.1 Paquete de autorización

- Planes de seguridad, privacidad y C-SCRM aplicables.
- Informes de evaluación de seguridad y privacidad.
- Plan de acción y hitos (POA plagaM).
- Resumen ejecutivo y evaluación del riesgo actual.
- Estrategia de vigilancia continua e información de cambio significativa.
- Descripción del sistema, categorización, límite, arquitectura, dependencias, herencia de control común y acuerdos.

Posible decision |

|. | tención Autorización para operar/utilizar | aceptado para el alcance definido, las condiciones y el tiempo TEN Autorización de control común | Decisión de riesgo para los controles heredados por múltiples sistemas TEN Autorización con condiciones TEN Operación permitida sólo con límites, acciones, hitos, o monitoreo | No se acepta el riesgo de muerte permanente; el funcionamiento/uso no está autorizado bajo condiciones declaradas | Aproximación de autorización continua TENENCIA Las pruebas actuales frecuentes son compatibles con decisiones de riesgo continuas bajo criterios aprobados |

No hay certificación: La autorización no significa que el sistema sea libre de riesgos o compatible para siempre. Es una aceptación documentada del riesgo residual actual por un funcionario con autoridad. | |

12. Monitor continuo

Monitor controla, cambia el sistema, amenaza, hallazgos y riesgo después de la autorización.

12.1 Monitoring activities

- Sistema de seguimiento, arquitectura, datos, misión, usuario, proveedor, propiedad, ubicación, amenaza, vulnerabilidad y cambios legales.
- Evaluar los controles seleccionados en frecuencias aprobadas y los desencadenantes del evento utilizando evidencia actual.
- Supervisar controles comunes y comunicar cambios a los sistemas hereditarios.
- Actualizar planes, inventarios, diagramas, resultados de evaluación, registro de riesgos y POA plagaM.
- Informar sobre la postura y el cambio material a los propietarios de sistemas, los ejecutivos de riesgo, los funcionarios de seguridad/privacy y autorizar a los funcionarios.
- Debilidades correctas, pruebas y determinar si un cambio significativo o un mayor riesgo requiere la reautorización o cambios de términos.

Monitor para las decisiones Recopilar sólo evidencia que tenga un propietario, propósito, regla de calidad, umbral, cadencia de revisión, escalada y respuesta. Más paneles no mejoran automáticamente la gestión del riesgo. | |.

13. Bases de control y adaptación

Las líneas de base son puntos de partida; la adaptación las hace apropiadas y defensibles.

■img src="media/image5.png" style="width:6.15in;height:3.39605in" alt="Tailoring cambia una base inicial en un conjunto de control documentado y basado en el riesgo."

Figura 4. Adaptación de control

Baseline

Bajo

Ø Moderate tención Inicio de controles de seguridad para sistemas federales de efecto moderado TEN High | Inicio de controles de seguridad para sistemas federales de alto impacto Controles de privacidad aplicados basados en el riesgo de procesamiento y privacidad, no el nivel de impacto del sistema solo

13.1 Tailoring record

- Base de referencia/profile y liberación utilizada.
- Control/enhancement añadido, eliminado, especializado, heredado o compensado.

- Racionalización y base de riesgo.
- Cada parámetro definido por la organización y autoridad de origen.
- Asignación y proveedor comunes/híbridos/sistemas específicos.
- Equivalencia compensatoria, limitación, aprobación y monitoreo.
- Riesgo residual, aprobador, fecha y futuro gatillo de revisión.

14. Controles comunes, híbridos y sistémicos

La asignación de control explica quién proporciona cada control y qué parte debe implementar el sistema.

Tipo

TEN Common tención Aplicada una vez para sistemas múltiples; heredados bajo el alcance definido tención Control de personal de la empresa o control de instalaciones físicas | específico para un sistema para una sola solución | TEN Híbrido | Parte común y parte sistema específico
 Ø Servicio de identidad de empresa más diseño de papel de aplicación | Inhered | System se basa en un proveedor de control autorizado | Servicio externo | Proveedor y responsabilidades de los clientes se definen por servicio y acuerdo | SaaS logging, cliente SSO, infraestructura de proveedores

14.1 Controles de herencia

- Se conoce el estado de la autorización, el alcance, la aplicación, las pruebas, la evaluación, las conclusiones, los cambios y la expiración.
- El control heredado realmente se aplica a la tecnología, ubicación, servicio y uso del sistema.
- Las responsabilidades de cliente/sistema se implementan y prueban.
- Los cambios y debilidades del proveedor se comunican a los sistemas hereditarios.
- Si el control común falla o se vuelve indisponible, los sistemas afectados reevalúan el riesgo y la respuesta.

15. Redacción de declaraciones de aplicación fuertes

Una declaración de implementación debe permitir que otra persona entienda y pruebe el control real.

“Estilo de control: 3.39605in” alt=“Los identificadores de control son insuficientes; los requisitos de lectura, los parámetros, la discusión y las mejoras juntos.” /

Figura 5. Anatomía de control

Declaración débil

TEN La organización utiliza el MFA. TEN Identidad equipo requiere el MFA resistente al phishing para funciones de administrador nombradas a través del servicio de identidad aprobado; inscripción, excepciones y revisión trimestral de cobertura se registran en sistemas específicos.

Los registros son revisados.

Los respaldos están realizados. TEN Operaciones crea copias de seguridad diarias encriptadas de las bases de datos Tier 1 listadas, mantiene una copia aislada, monitorea fallos y realiza pruebas trimestrales de restauración contra RTO de cuatro horas y RPO de 30 minutos.

15.1 Lista de comprobación de estados

- ¿Quién posee y realiza el control?
- ¿Qué sistemas, cuentas, datos, instalaciones, proveedores y población están cubiertos?
- ¿Qué proceso, configuración, herramienta, regla y parámetro lo implementa?
- ¿Dónde funciona y dónde se conservan las pruebas?
- ¿Cuándo/frecuencia/trigger y qué tan rápido?
- ¿Cómo se manejan las aprobaciones, excepciones, fallos, revisiones, métricas, cambios y pruebas?
- ¿Cuál parte es heredada, compartida, planificada, no aplicable o aún no opera?

16. Assessment Planning and Evidence

Los procedimientos del SP 800-53A se adaptan a un plan de evaluación aprobado.

“Methods, objetos, profundidad y cobertura deben ajustarse al objetivo y al riesgo.” / título

Gráfico 6 Estructura del procedimiento de evaluación

Element |**

|... | | Objetivo de evaluación | Qué determinación el procedimiento está diseñado para apoyar |
Método | Examinar, entrevistar o probar TENCIÓN FORMULADA , mecanismo, actividad,
individuo o evidencia examinada — Depth tención Nivel de rigor/detalles: básica, enfocada o
integral tención TENCIÓN TENIDA Pantalones o alcances: básica, enfocada o completa TENER
Evidencia TENIDA Información fiable en apoyo de la determinación Silencioso Result |
Satisfecho u otro que satisfecho, con excepciones y limitaciones

16.1 Población y muestreo

- Identificar la población completa antes de elegir una muestra.
- Validar la integridad y exactitud utilizando fuentes independientes cuando sea posible.

- Seleccione pruebas de población completa cuando la automatización y el riesgo lo hacen práctico.
- Para muestras, método de documento, período, tamaño, estratos, base aleatoria/judgmental y limitación.
- Ampliar las pruebas cuando las excepciones sugieren un patrón o debilidad de la población.

17. Paquete de Autorización y POA plagam

El paquete cuenta la historia de riesgo del propósito del sistema para abrir debilidad y monitoreo.

17.1 POAюM quality

- Unico hallazgo y control exacto/criterios.
- Condición, población afectada, evidencia, fecha y fuente.
- Situación de riesgo, situación de probabilidad/contexto de impacto, gravedad y dependencia.
- Causa y acción correctiva planificada - no sólo un síntoma.
- Hitos, recursos, propietario responsable, terminación programada y salvaguardias provisionales.
- Cambios, demoras, aprobaciones, riesgo residual y escalada.
- Procedimiento de protesta, pruebas, resultados, revisión de cierre y fecha.

■table ■colgroup "Anchura: 35%" "Anchura: 64%" ■/colgroup - No. "Clase de dirección" - No. - No. " Secundaria " - No. - No. " Secundaria " ■/tr título ■/thead Identificado "Clase" Identificado ¿Qué está siendo autorizado? > > > > , información, arquitectura, dependencias realizadas ■/tr título #####

Identificado ¿Qué controles deben aplicarse? " Categorization, baseline, tailoring, parameters, requirements ■/tr título "Clase" ¿Cómo se implementan los controles? < > > > > > } ■/tr título #####

¿Operan los controles? < > > > > > > ■/tr título "Clase" ¿Qué riesgo queda? < > > > > > > > > ■/tr título #####

¿Cómo riesgo permanecer visible? < > > > > > ■/tr título Identificado/tbody ■/table

18. Estrategia de vigilancia continua

Una estrategia de vigilancia define qué pruebas se recogen, con qué frecuencia y qué decisión sigue.

Altura:3.39605in” alt=“Monitoring cierra el bucle del cambio y la evidencia para corregir las decisiones de riesgo.” / Propiedad

Gráfico 8 Supervisión y respuesta continuas

Field | Example decision content

|. | | Control/riesgo ¿Qué requisito y riesgo se dirigen las pruebas | Ø Indicador Silencioso Configuración, cobertura, evento, hallazgo, desempeño, excepción o cambio Fuente/propietario | Sistema autorizado y responsable de los datos – Frecuencia/trigger | Daily, mensual, anual, lanzamiento, incidente, cambio de proveedor, cambio significativo tención TEN Quality ANTE Completeness, accuracy, timeliness, integrity, access, time synchronization | TENISTERIO | Condición que requiere revisión, escalada, corrección, reevaluación o autorización acción | tención Audience | Aplicador, propietario del sistema, funcionario de seguridad/privacy, ejecutivo de riesgo, autorizando la detención – Retención | Historia requerida, protección de pruebas y actualización de paquetes

19. OSCAL and Automation

OSCAL apoya la información de control, implementación, evaluación y remediación legible por máquina.

img src=“media/image9.png” style=“width:6.15in;height:3.39605in” alt=“OSCAL modelos conectan lo que se requiere, cómo se implementa, cómo se evalúa, y lo que permanece abierto.”

Figura 9. Flujo de modelo OSCAL

Silencioso ** Modelo OSCAL** |. | | Catálogo | Controles estructurados, mejoras, parámetros y contenido de soporte | TEN Perfil | Selecciona, modifica y organiza controles de catálogos | tención Componente Definición | Describe las capacidades de implementación de control reutilizables Plan de Seguridad del Sistema Silencioso Describir el sistema y controlar la implementación Silencioso Plan de Evaluación | Define el alcance de la evaluación, temas, tareas, métodos y horarios Silenciosos resultados de evaluación tención Plan de Acción y Hitos Silenciosos Temas riesgos, hallazgos, acciones, hitos y estatus

19.1 Salvaguardias de automatización

- Tratar la liberación oficial y el esquema como dependencias controladas.

- Validar la sintaxis y semántica; los datos schema-valid todavía pueden ser de hecho incorrectos.
- Usar identificadores estables y rastrear evidencia a los sistemas fuente.
- Proteger el sistema sensible, la arquitectura, la debilidad, la información personal y el proveedor.
- Exigir un examen humano para la adaptación, el riesgo, las conclusiones, las excepciones y las decisiones de autorización.
- Seguimiento de la versión, cambio, aprobación, transformación, herencia e historia de exportación.

20. Familias de control: acceso, conciencia, auditoría y evaluación

Four families establish who may act, how people learn, what is logged, and how assurance decisions are made.

AC — Access Control

Limite el acceso de sistema e información a usuarios autorizados, procesos, dispositivos y acciones permitidas.

Implementation focus

tención Definir el alcance, propietario, requisitos, procedimientos, tecnología, responsabilidades, excepciones y monitoreo. inventario, roles, aprobaciones, MFA, reglas de acceso, revisiones, revocaciones, registros

AT — Awareness and Training

Fomentar la conciencia general y el conocimiento específico de las responsabilidades de seguridad y privacidad.

Implementation focus

tención Definir el alcance, propietario, requisitos, procedimientos, tecnología, responsabilidades, excepciones y monitoreo. tención de la población, el plan de estudios, la asignación de roles, la terminación, ejercicios, excepciones, evaluación

AU — Audit and Accountability

Crear, proteger, revisar, conservar y utilizar registros que apoyen la detección, investigación y rendición de cuentas.

Implementation focus | Posibles pruebas Silencioso**

|

— La vida eterna— | tención Definir el alcance, propietario, requisitos, procedimientos, tecnología, responsabilidades, excepciones y monitoreo. | Lista de eventos, fuentes de registro, sincronización de tiempo, campos, retención, acceso, revisión, alertas | evidencia al control exacto; validar la población, fecha, configuración, operación, excepciones, y retest.

CA — Assessment, Authorization, and Monitoring

Evaluar los controles, gestionar los hallazgos, autorizar el riesgo y supervisar la seguridad y la postura de privacidad.

Implementation focus | Posibles pruebas Silencioso**

|

— La vida eterna— | tención Definir el alcance, propietario, requisitos, procedimientos, tecnología, responsabilidades, excepciones y monitoreo. — Planes de evaluación/reportaciones, autorizaciones, POA plagaM, estrategia de monitoreo, resultados | evidencia al control exacto; validar la población, fecha, configuración, operación, excepciones, y retest.

21. Familias de control: configuración, contingencia, identidad, incidentes y mantenimiento

Estas familias aseguran la configuración, resiliencia, identidad, respuesta y mantenimiento controlado.

CM — Configuration Management

Establecer bases de referencia controladas y gestionar la configuración y el cambio seguros.

Implementation focus

tención Definir el alcance, propietario, requisitos, procedimientos, tecnología, responsabilidades, excepciones y monitoreo. TEN Baselines, inventarios, aprobaciones, pruebas de cambio, escaneos, desviaciones, revisiones

CP — Contingency Planning

Preparar, probar y mantener las capacidades de recuperación y continuidad.

Implementation focus

tención Definir el alcance, propietario, requisitos, procedimientos, tecnología, responsabilidades, excepciones y monitoreo. TEN BIA, planes, copias de seguridad,

Implementation focus

procesamiento alternativo, ejercicios, restauraciones, evidencia RTO/RPO

IA - Identificación y autenticación

Únicamente identificar y autenticar personas, dispositivos y procesos con una fuerza adecuada al riesgo.

Implementation focus

tención Definir el alcance, propietario, requisitos, procedimientos, tecnología, responsabilidades, excepciones y monitoreo. prueba de identidad, autenticadores, MFA, federación, identidades de servicio, registros de ciclo de vida

IR — Respuesta de incidentes

Prepárate para, detecta, analiza, contiene, recupera, reporta y mejora después de incidentes.

Implementation focus

tención Definir el alcance, propietario, requisitos, procedimientos, tecnología, responsabilidades, excepciones y monitoreo. Plan, roles, libros de juego, casos, evidencia, notificación, ejercicios, lecciones

MA — Maintenance

Mantenimiento, herramientas, personal, acceso y actividad remota del sistema de control.

Implementation focus

tención Definir el alcance, propietario, requisitos, procedimientos, tecnología, responsabilidades, excepciones y monitoreo. Calendario de mantenimiento, aprobaciones, herramientas, sanitización, sesiones remotas, logs tención Pruebas coinciden con el control exacto; validar la población, fecha, configuración, operación, excepciones, y retest.

22. Familias de control: Medios, Física, Planificación, Programa y Personal

Estas familias protegen medios, instalaciones, planes, programas y personal.

MP — Media Protection

Proteger, controlar, transportar, sanitizar y disponer de medios digitales y no digitales.

Implementation focus

tención Definir el alcance, propietario, requisitos, procedimientos, tecnología, responsabilidades, excepciones y monitoreo. Silencioso inventario de medios, acceso, marcación, transporte, encriptación, sanitización, eliminación

PE - Protección física y ambiental

Protege instalaciones, equipos, servicios públicos y personas de amenazas físicas y ambientales.

Implementation focus | Posibles pruebas Silencioso**

|

— La vida eterna— | tención Definir el alcance, propietario, requisitos, procedimientos, tecnología, responsabilidades, excepciones y monitoreo. Silenciosas, visitantes, cámaras, alarmas, potencia, fuego, temperatura, instalaciones críticas TENENCIA Pruebas coinciden con el control exacto; validar la población, fecha, configuración, operación, excepciones y retest. |

PL — Planning

Planes de seguridad y privacidad del sistema de documentos, reglas de comportamiento, arquitectura y controles previstos.

Implementation focus

tención Definir el alcance, propietario, requisitos, procedimientos, tecnología, responsabilidades, excepciones y monitoreo.

PM — Gestión de programas

Operar programas de seguridad y privacidad de la información en toda la organización y gobernanza compartida.

Implementation focus

tención Definir el alcance, propietario, requisitos, procedimientos, tecnología, responsabilidades, excepciones y monitoreo. Planes de programas, líderes, recursos, estrategia de riesgo, métricas, inventarios de empresas TENA evidencia al control exacto; validar la población, fecha, configuración, operación, excepciones, y retest.

PS — Seguridad del Personal

Gestionar el control del personal, los acuerdos, las transferencias, la terminación, las sanciones y el riesgo.

Implementation focus

tención Definir el alcance, propietario, requisitos, procedimientos, tecnología, responsabilidades, excepciones y monitoreo. tención de pruebas, acuerdos, cambios de roles, terminación de acceso, personal de terceros

23. Familias de control: Privacidad, Riesgo, Adquisición, Comunicaciones, Integridad y Cadena de Suministro

Estas familias cubren PII, riesgo, adquisición, arquitectura/comunicaciones, integridad y cadenas de suministro.

PT — PII Procesamiento y Transparencia

Administrar los propósitos de procesamiento, autoridad, minimización, consentimiento, aviso, acceso, corrección y responsabilidad de privacidad.

Implementation focus

tención Definir el alcance, propietario, requisitos, procedimientos, tecnología, responsabilidades, excepciones y monitoreo. tención Inventario de datos, finalidad/autoridad, avisos, consentimiento, minimización, derechos, evaluaciones

RA — Risk Assessment

Identificar amenazas, vulnerabilidades, probabilidad, impactos, problemas de privacidad y respuestas de riesgo.

Implementation focus

tención Definir el alcance, propietario, requisitos, procedimientos, tecnología, responsabilidades, excepciones y monitoreo.

SA — Adquisición de sistemas y servicios

Construir seguridad y privacidad en la adquisición, desarrollo, ingeniería, oferta y servicios externos.

Implementation focus

tención Definir el alcance, propietario, requisitos, procedimientos, tecnología, responsabilidades, excepciones y monitoreo. Ø Requisitos, contratos, SDLC, arquitectura, desarrolladores, pruebas, SBOM, evidencia de proveedores TENA evidencia para el control exacto; validar la población, fecha, configuración, operación, excepciones y retest.

SC — Protección de sistemas y comunicaciones

Protege límites, comunicaciones, arquitectura, criptografía, aislamiento y recursos compartidos.

Implementation focus

tención Definir el alcance, propietario, requisitos, procedimientos, tecnología, responsabilidades, excepciones y monitoreo. Ø Diagramas, segmentación, reglas de cortafuegos, encriptación, claves, protocolos, pruebas de límites

SI — System and Information Integrity

Encontrar y corregir defectos, código malicioso, fallas de integridad, actualizaciones inseguras y comportamiento anómalo.

Implementation focus

tención Definir el alcance, propietario, requisitos, procedimientos, tecnología, responsabilidades, excepciones y monitoreo. Ø vulnerabilidades, parches, validación de la integridad, defensas de malware, alertas, correcciones

SR — Supply Chain Risk Management

Gestionar riesgos de productos, servicios, proveedores, desarrolladores, integradores y cadena de suministro.

Implementation focus

tención Definir el alcance, propietario, requisitos, procedimientos, tecnología, responsabilidades, excepciones y monitoreo. TEN C-SCRM plan, inventario de proveedores, crítica, contratos, procedencia, monitoreo, salida

24. Riesgo de privacidad y seguridad – Colaboración de privacidad

Rev. 5 integra los controles de seguridad y privacidad preservando al mismo tiempo objetivos y métodos de riesgo distintos.

24.1 Colaboración

- La seguridad gestiona los riesgos de la pérdida de confidencialidad, integridad y disponibilidad a operaciones, activos, personas, otras organizaciones y la Nación.
- Gestión del riesgo de privacidad examina los problemas que las personas pueden experimentar desde el procesamiento de datos, incluso cuando los controles de seguridad funcionan según lo diseñado.
- Los controles conjuntos necesitan una clara propiedad en materia de seguridad y privilegios, una aplicación compartida, pruebas, evaluaciones, conclusiones y comunicación sobre riesgos.
- Los controles de PT abordan el procesamiento de PII y la transparencia; los controles pertinentes en todas las familias también pueden apoyar la privacidad.
- La selección y la adaptación de la base de datos de privacidad dependen del procesamiento, propósito, autoridad, personas, datos, contexto y riesgo de privacidad, no sólo de impacto FIPS.

Pregunta |

|... | ¿Por qué se procesan los datos? – Propósito, autoridad, sistema/ plan de privatización
¿Qué datos y personas? inventario de datos, tipos de información, flujo de datos ¿Qué problemas podrían crear el procesamiento? Evaluación del riesgo de privacidad / PIA como aplicable TEN
¿Cómo se procesa limitado y explicado? Minimización, aviso, consentimiento, retención, participación, procedimientos de derechos ¿Cómo se coordinan los controles de seguridad y privacidad? tención Índice de colaboración, asignaciones, pruebas conjuntas y conclusiones

25. Actualizaciones de software, fiabilidad de parche, y liberación

5.2.0

Release 5.2.0 fortalece la actualización de software, parche, integridad y cobertura de desarrollo resiliente.

Release 5.2.0 cambio |

|. | TEN SA-15(13) — proceso de desarrollo, estándares y mejora de herramientas TENENCIA
Añade atención a las prácticas de desarrollo de software resistente relacionadas con actualizaciones y parches | TEN SA-24 — Diseño para la Resiliencia Cibernética TENER Nuevo control enfatizando el diseño del sistema/software que puede soportar, recuperar, adaptar y continuar en condiciones adversas TEN SI-02(07) — mejora de la remediación de fallas | Añade requisitos centrados en actualizaciones de software/firmware confiables y seguras | SI-07(12) — revisión del mejoramiento de la verificación de la integridad | | Discusión / actualizaciones relacionadas con el control | Clarifies adquisición, diseño, documentación, gestión de actualizaciones, integridad, monitoreo, incidentes y relaciones de evaluación | SP 800-53A 5.2.0 | Añade los procedimientos correspondientes para los nuevos controles/enhancements tención SP 800-53B 5.2.0 Ø Reissued for consistency; NIST indica que las selecciones de base no cambiaron

25.1 Enfoque de evidencia

- Actualizar el origen, la firma, la verificación de la integridad, la entrega protegida, la aprobación, las pruebas, la devolución, la manipulación de fallos, el inventario, la cobertura del despliegue, la vigilancia y los registros.
- Prácticas de desarrollo y proveedores, acceso a la construcción y liberación, procedencia, SBOM, respuesta a la vulnerabilidad, período de soporte, final de vida y comunicación de clientes.
- Hipótesis de diseño resistentes, comportamiento de condición adversa, aislamiento, degradación, recuperación, diversidad, redundancia y resultados de ejercicio.

26. Open-Source Tools and Official Resources

Los recursos oficiales y los instrumentos de código abierto pueden apoyar la autorización, las pruebas, la evaluación y la vigilancia continua.

Recurso/herramienta |

|... | tención NIST CPRT tención Controles oficiales actuales, bases de referencia, procedimientos y descargas Ø Contenido oficial de control NIST OSCAL Cumplimiento permanente Trestle Silencioso OSCAL Autorización, transformación y gobernanza | Lula | Evaluar las pruebas de control como código | CISO Asistente | Riesgo, controles, pruebas, evaluaciones y hallazgos | Heimdall | Vista y normalizar los resultados de la evaluación de la seguridad | OpenControl | documentación de cumplimiento como texto estructurado Silencioso OSCAL CLI | Validar y transformar el contenido OSCAL TEN Wazuh TENRI Endpoint monitoring, file integrity, log analysis, and alerts | TEN OpenSCAP | Configuración y evaluación de la vulnerabilidad TEN Osquery TEN TEN Endpoint inventario y consultas de configuración | Nmap | Autorizado activo y descubrimiento de servicios | Greenbone Community Edition | Evaluación de vulnerabilidad autorizada Repositorio, imagen, dependencia, secreto y cheques de IaC | OWASP ZAP ▶ | – Keycloak – Identidad, roles, MFA, sesiones y eventos de auditoría – DefectDojo tóxico Encontrar una agregación, asignación, remediación y retestigo TEN Open Policy Agent | Decisiones de política como código

Autorización y límites: Utilice herramientas técnicas sólo en sistemas, redes, repositorios, datos y cuentas que posee o tiene permiso escrito para probar. Una herramienta puede apoyar pruebas; no puede elegir tolerancia al riesgo, aprobar la adaptación, aceptar el riesgo o emitir autorización. | Respuesta

26.1 NIST CPRT

Propósito: Controles oficiales de corriente, bases de referencia, procedimientos y descargas. Proyecto oficial: [Seguido] (<https://csrc.nist.gov/projects/cprt/catalog>)

Inicio rápido seguro: Abra el catálogo, seleccione SP 800-53 Release 5.2.0, revise el control exacto y la discusión, luego exporte un formato aprobado y la versión de registro/fecha.

Retain: authority, scope, source/release, version, configuración/query, population, date, raw result, analista validation, limitation, control mapping, finding, correction, and retest. Proteger el sistema y la información de vulnerabilidad.

26.2 NIST OSCAL Content

Propósito: Contenido oficial de control NIST legible por máquina. Proyecto oficial: [](<https://github.com/usnistgov/oscal-content>)

Inicio rápido seguro: Cerrar o descargar una versión etiquetada, validar la identidad de archivo, inspeccionar el catálogo / archivo SP 800-53 y preservar la versión fuente.

Retain: authority, scope, source/release, version, configuración/query, population, date, raw result, analista validation, limitation, control mapping, finding, correction, and retest. Proteger el sistema y la información de vulnerabilidad.

26.3 Compliance Trestle

Objetivo: Autorización, transformación y gobernanza OSCAL. Proyecto oficial: [ejecutado]Compliance Trestle obtenidos/u contacto](<https://github.com/oscal-compass/compliance-trestle>)

Inicio rápido seguro: Crear un espacio de trabajo de laboratorio, importar OSCAL oficial, autor de un pequeño perfil y definición de componentes, validar, revisar cambios y exportar.

Retain: authority, scope, source/release, version, configuración/query, population, date, raw result, analista validation, limitation, control mapping, finding, correction, and retest. Proteger el sistema y la información de vulnerabilidad.

26.4 Lula

Propósito: Evaluar la evidencia de control como código. Proyecto oficial: [Seguido](#)

Inicio rápido seguro: Usar un repositorio de laboratorio, definir una validación no destructiva mapeada a un control, ejecutarlo contra datos sintéticos o autorizados, revisar evidencia y ver el resultado.

Retain: authority, scope, source/release, version, configuración/query, population, date, raw result, analista validation, limitation, control mapping, finding, correction, and retest. Proteger el sistema y la información de vulnerabilidad.

26.5 CISO Assistant

Propósito: Riesgo, controles, pruebas, evaluaciones y hallazgos. Proyecto oficial: [Seguido](#)

Inicio rápido seguro: Crear un proyecto de alcance, cargar un marco relevante, asignar propietarios, implementación de documentos, adjuntar evidencia, evaluar y rastrear hallazgos.

Retain: authority, scope, source/release, version, configuración/query, population, date, raw result, analista validation, limitation, control mapping, finding, correction, and retest. Proteger el sistema y la información de vulnerabilidad.

26.6 Heimdall

Objetivo: Ver y normalizar los resultados de la evaluación de la seguridad. Proyecto oficial: [Seguido](#)

Inicio rápido seguro: Importar un resultado de muestra aprobado, confirmar mapas y puntuación, revisar excepciones, restringir el acceso y exportar un informe sanitario.

Retain: authority, scope, source/release, version, configuración/query, population, date, raw result, analista validation, limitation, control mapping, finding, correction, and retest. Proteger el sistema y la información de vulnerabilidad.

26.7 OpenControl

Propósito: Documentación de cumplimiento como texto estructurado. Proyecto oficial: [Seguido](#)

Inicio rápido seguro: Crear un componente de laboratorio, mapear un control, escribir detalles de la implementación y referencias de evidencia, revisión por pares y seguimiento en control de versiones.

Retain: authority, scope, source/release, version, configuración/query, population, date, raw result, analista validation, limitation, control mapping, finding, correction, and retest. Proteger el sistema y la información de vulnerabilidad.

26.8 OSCAL CLI

Propósito: Validar y transformar contenido OSCAL. Proyecto oficial: [Seguido](#)

Inicio rápido seguro: Validar un pequeño archivo OSCAL de laboratorio, errores de esquema correctos, transformar sólo con versiones aprobadas, y mantener la salida de validación.

Retain: authority, scope, source/release, version, configuración/query, population, date, raw result, analista validation, limitation, control mapping, finding, correction, and retest. Proteger el sistema y la información de vulnerabilidad.

26.9 Wazuh

Propósito: Supervisión de puntos finales, integridad de archivos, análisis de registros y alertas. Proyecto oficial: [Seguido](#)

Inicio rápido seguro: Inscribir un punto final de laboratorio, generar un evento inofensivo, validar la recogida y alerta, cobertura de documentos y limitaciones, y retener evidencia.

Retain: authority, scope, source/release, version, configuración/query, population, date, raw result, analista validation, limitation, control mapping, finding, correction, and retest. Proteger el sistema y la información de vulnerabilidad.

26.10 OpenSCAP

Propósito: Configuración y evaluación de vulnerabilidad. Proyecto oficial: [Seguido](#)

Inicio rápido seguro: Elija un perfil aplicable para un sistema de laboratorio, ejecute un escaneo autorizado, valide los resultados, ajuste de documentos, remedia y recan.

Retain: authority, scope, source/release, version, configuración/query, population, date, raw result, analista validation, limitation, control mapping, finding, correction, and retest. Proteger el sistema y la información de vulnerabilidad.

26.11 osquery

Finalidad: inventario y consultas de configuración. Proyecto oficial: (<https://www.osquery.io/>)

Inicio rápido seguro: Ejecutar consultas de laboratorio sólo lectura, definir la población, comparar resultados con requisitos, validar excepciones, y registrar consultas/versión.

Retain: authority, scope, source/release, version, configuración/query, population, date, raw result, analista validation, limitation, control mapping, finding, correction, and retest. Proteger el sistema y la información de vulnerabilidad.

26.12 Nmap

Propósito: Activo autorizado y descubrimiento de servicios. Proyecto oficial: [Seguido](#)

Comienzo rápido seguro: Escanear sólo rangos escritos con opciones limitadas, reconciliarse con el inventario, investigar desconocidos, y preservar el alcance y las pruebas de comando.

Retain: authority, scope, source/release, version, configuración/query, population, date, raw result, analista validation, limitation, control mapping, finding, correction, and retest. Proteger el sistema y la información de vulnerabilidad.

26.13 Greenbone Community Edition

Objetivo: Evaluación autorizada de la vulnerabilidad. Proyecto oficial: [ejecutado]Greenbone Community Edition (10)(<https://greenbone.github.io/docs/latest/>)

Inicio rápido seguro: Actualizar los alimentos, definir los objetivos y las credenciales aprobados, validar la cobertura, revisar los hallazgos, corregir y cambiar.

Retain: authority, scope, source/release, version, configuración/query, population, date, raw result, analista validation, limitation, control mapping, finding, correction, and retest. Proteger el sistema y la información de vulnerabilidad.

26.14 Trivy

Propósito: Repositorio, imagen, dependencia, secreto y cheques IaC. Proyecto oficial: [Seguido](#)

Inicio rápido seguro: Escanear un repositorio de entrenamiento autorizado o imagen, validar conclusiones, corregir o documentar excepciones aprobadas, y rescane en CI.

Retain: authority, scope, source/release, version, configuración/query, population, date, raw result, analista validation, limitation, control mapping, finding, correction, and retest. Proteger el sistema y la información de vulnerabilidad.

26.15 OWASP ZAP

Propósito: Pruebas de seguridad de aplicaciones web autorizadas. Proyecto oficial: [Seguido] (<https://www.zaproxy.org/>)

Inicio rápido seguro: Usar una aplicación de entrenamiento, arrastrar pasivamente, utilizar el escaneo activo sólo con permiso, validar hallazgos, fijar y retest.

Retain: authority, scope, source/release, version, configuración/query, population, date, raw result, analista validation, limitation, control mapping, finding, correction, and retest. Proteger el sistema y la información de vulnerabilidad.

26.16 Keycloak

Propósito: Identidad, funciones, MFA, sesiones y eventos de auditoría. Proyecto oficial: [Seguido](#)

Comenzar rápido seguro: Crear un reino de laboratorio, configurar roles y MFA, probar el ensamblador de pruebas y casos privilegiados, y revisar eventos.

Retain: authority, scope, source/release, version, configuración/query, population, date, raw result, analista validation, limitation, control mapping, finding, correction, and retest. Proteger el sistema y la información de vulnerabilidad.

26.17 DefectoDojo

Propósito: Encontrar agregación, asignación, remediación y retest. Proyecto oficial: [Seguido](#)

Comienzo rápido seguro: Importar hallazgos de laboratorio seguros, validar la deduplicación y gravedad, asignar acción, adjuntar evidencia, y cerrar sólo después de la prueba.

Retain: authority, scope, source/release, version, configuración/query, population, date, raw result, analista validation, limitation, control mapping, finding, correction, and retest. Proteger el sistema y la información de vulnerabilidad.

26.18 Open Policy Agent

Objetivo: Decisiones de política como código. Proyecto oficial: [Seguido](#)

Inicio rápido seguro: Escribir una pequeña política de laboratorio para una regla de configuración aprobada, probar casos de permiso/negación y fracaso, revisión por pares, decisiones de registro y preservar la autoridad de excepción humana.

Retain: authority, scope, source/release, version, configuración/query, population, date, raw result, analista validation, limitation, control mapping, finding, correction, and retest. Proteger el sistema y la información de vulnerabilidad.

27. Manual del RMF para gerentes

Managers keep RMF focused on mission risk, reliable evidence, timely decisions, and correction.

Area | Pregunta principal | | ¿Sabemos qué hay dentro, heredado, conectado y proporcionado externamente? | Nube desconocida, proveedor, o camino de administración | Categorization | ¿El impacto refleja todo tipo de información, dependencia, privacidad, seguridad y efecto de misión? | Categoría copiado de otro sistema tención Selección | ¿Están justificadas las bases de referencia, la adaptación, los parámetros, las adiciones y las asignaciones? | Conjunto de control tratado como lista de verificación sin cola ¿Pueden los propietarios explicar quién / qué / dónde / cuándo y mostrar pruebas de funcionamiento? | Lenguaje de política copiado como implementación ¿Son creíbles el alcance, la población, los métodos, la independencia, las limitaciones y las pruebas? tención Escáner es igual a la evaluación | Autorización | ¿El funcionario de la decisión entiende el riesgo residual y las condiciones? | Paquete oculta incertidumbre grave/abierto – Monitorización | ¿Los cambios e indicadores conducen a la respuesta y actualizaciones de paquetes? | Dashboard sin acción responsable ¿Se financian acciones severas y atrasadas y se prueban de forma independiente? Extensiones repetidas sin decisión de riesgo

27.1 Gestor ritmo

- Mensual: hallazgos severos, cambios significativos, cambios atrasados, cambios de control común, umbrales de monitoreo y condiciones de autorización.
- Trimestralmente: control de las tendencias de calidad, vulnerabilidad y configuración, riesgos de proveedores, riesgos de privacidad, resultados de recuperación/incidente y bloqueadores de recursos.
- En versiones o cambios importantes: límite, categorización, conjunto de control, evaluación y impacto de autorización.
- Ciclo anual o aprobado: estrategia de riesgo, controles comunes, valores de parámetro, estrategia de monitoreo, capacidad de evaluación, calidad de paquete, métricas y mejora de procesos.

28. Guía de la carrera de analista junior

Los analistas Junior RMF crean valor a través de límites precisos, mapas, declaraciones, evidencias, hallazgos y seguimiento.

■img src="media/image10.png" estilo="width:6.15in;height:3.39605in" alt="Trace cada conclusión del requisito a la implementación, evidencia, resultado, riesgo, y acción."

Gráfico 10 Júnior RMF vía analista

28.1 Funciones comunes

- Junior GRC Analista
- RMF Analista
- Asesor de Control de Seguridad (junior)
- Apoyo del Oficial de Seguridad del Sistema de Información
- Analista de Cumplimiento de Ciberseguridad
- Análisis de la autorización de seguridad
- Análisis de Controles de Privacidad
- Analista de Monitoreo continuo

28.2 Típico trabajo

- Mantener el inventario del sistema, los límites, los tipos de información, las categorizaciones, la asignación de control, las pruebas, las conclusiones, las versiones de POA plagam y los paquetes.
- Lea texto y procedimientos de control exactos; descargue récord y parámetros definidos por la organización.
- Proyectos de declaración de ejecución y validarlos con propietarios y pruebas.

- Reunir pruebas de forma segura, validar la calidad de la población y de la fuente, realizar los pasos aprobados de examen/interview/test y limitar los documentos.
- Escribir hallazgos claros y hitos de pista a través de pruebas independientes.
- Usar CPRT, OSCAL, hojas de cálculo, repositorios, paneles y herramientas técnicas aprobadas sin reclamar autoridad más allá del papel.

29. Laboratorio Ficcional, Plan de Treinta Días y Preparación de Entrevistas

Un sistema ficticio y un laboratorio autorizado pueden convertirse en una sólida cartera de nivel de entrada.

- La regla del laboratorio* Utilizar organizaciones ficticias, datos sintéticos, sistemas aislados y autorización escrita. Nunca escanee objetivos públicos o publique planes de sistema real, vulnerabilidades, credenciales, diagramas o pruebas de evaluación.
- Respuesta

29.1 Portfolio lab

- Crear una organización ficticia de 100 personas y un portal de clientes anfitriones en la nube con un proveedor de identidad, base de datos, tubería CI/CD, proveedor de soporte y datos personales.
- Definir misión, partes interesadas, límites, inventario, arquitectura, flujo de datos, dependencias, servicios externos y asignación de control.
- Categorizar la confidencialidad, la integridad y la disponibilidad con tipos de información documentados y la racionalización del impacto.
- Seleccione una base de referencia moderada como punto de partida educativo; ajuste 20 controles representativos y parámetros con lógica de riesgo ficticio.
- Escribir diez fuertes declaraciones de implementación en diferentes familias.
- Crear un plan de evaluación y probar cinco controles usando pruebas sintéticas y herramientas de laboratorio autorizadas.
- Escribir dos hallazgos, un POA plagaM, pruebas de corrección y resultados de reprobación.
- Crear una breve guía de autorización y una estrategia continua de vigilancia.
- Representar un perfil, fragmento SSP, resultado de evaluación, o POA plagaM en OSCAL y validarlo.
- Publicar artefactos sanitizados claramente etiquetados ficticios y no una autorización NIST.

29.2 Plan de 30 días

Días

1–4

TEN 5–7

TEN 8–11

12–15 Silencioso Aplicación y estudio de la familia

TEN 16–19

tención 20–22 Silencioso Findings, risk, POA plagaM, retest Dos registros de hallazgo a cierre | 23–25 | Autorización y vigilancia | Estrategia ejecutiva breve y de vigilancia Ø 26–27 Silencioso OSCAL y herramientas aprobadas TEN 28–30 | Portfolio y entrevista | Portafolio Sanitizado y cinco historias de STAR

29.3 ¿Qué es RMF?

Un proceso de ciclo de vida de siete pasos para gestionar el riesgo de seguridad y privacidad: Preparar, Categorizar, Seleccionar, Implementar, Evaluar, Autorizar y Monitorizar.

29.4 ¿Es SP 800-53 una lista de verificación?

No. Es un catálogo de control flexible. Las organizaciones eligen y ajustan los controles mediante la gestión de riesgos y los requisitos aplicables.

29.5 ¿Qué es una base de referencia?

Un conjunto inicial de controles. SP 800-53B proporciona bases de referencia bajas, moderadas, altas y de privacidad para uso federal.

29.6 ¿Qué está adaptando?

Escopia documentada, parámetros, adiciones, especialización, asignación y controles de compensación aprobados que hacen que el conjunto de inicio se ajuste al sistema y el riesgo.

29.7 ¿Qué es la herencia de control?

Un sistema se basa en un control proporcionado por otro proveedor autorizado, al tiempo que sigue implementando y probando sus propias responsabilidades de clientes.

29.8 ¿Cómo evalúas un control?

Use objetivos aprobados y examine, entrevista o métodos de prueba con objetos definidos, profundidad, cobertura, población, evidencia, excepciones y limitaciones.

29.9 ¿Qué es la autorización?

La decisión de un funcionario superior autorizado de aceptar un riesgo residual definido para un sistema o controles comunes en términos declarados.

29.10 ¿Qué es un POA?"

Un plan rastreado para corregir debilidades identificadas, con riesgo, propietario, hitos, recursos, calendario, estado y retest.

29.11 ¿Qué es OSCAL?

Modelos legibles para máquinas NIST para controles, perfiles, implementaciones, evaluaciones, resultados y POA plagaMs.

29.12 ¿Qué es el SP 800-53 actual?

Revisión 5, Comunicado 5.2.0, emitido en agosto de 2025.

30. Plantillas, Glosario, Índice y Referencias

- Estructuras de trabajo reutilizables, términos clave, índice de sujeto y fuentes oficiales.*

30.1 Registro de sistemas y límites

|** | |... | "Sistema/propietario/misión" "La autorización de la autoridad en la vida" "La información sobre los tipos de información y el flujo de datos son insostenibles" "Antes Arquitectura/interfaces" Los servicios externos/los proveedores de la vida siguen adelante. Controles/herencia comunes en la vida "Dependencias/localizaciones" | Categoría/racional | "La etapa/cambios del ciclo de vida en la vida" "Aprobaciones/versión en la vida"

30.2 Documento de trabajo sobre la aplicación del control

|** | |... | , control/enhancement/release |
| Parameter/requirement | "Asignación/providente en la vida" "La vida escoge/población"
¿Quién? ¿Cómo? | cuando / gatillo/frecuencia |
| Evidencia/fuente/retención | "Excepción/failure/review" "Prisionista/aprobada/actualizada"

30.3 Assessment and finding record

|** | |. | | Objetivo/método/objeto |
| DEPTH/coverage/period |
| POBREZA/Sample/reliability | Los pasos/herramientas/versión incurrieron en la vida
Evidencia/resultar la situación actual Excepción / población afectada "Asunto/porque viviste"
"Acción/propietario/miles de piedras preciosas" "La protección provisional de la vida"
"Retest/closure" (Retest/closure) "Perfecto"

30.4 Registro de autorización y seguimiento

|** | |... | | Paquete/versión/fecha |
Silencioso resumen del riesgo confidencialidad
"La decisión/oficial/termina" "Permiso" Las condiciones de vida/expiración siguen adelante. |
POA CENTRO M / graves riesgos |
"Indicadores/fuentes/frecuencias" TENIENDO EL ESPECTO/EScalation TEN

Los disparadores de cambio significativos de la vida TENIENDO PRESENTACIÓN DE
INFORMES/Envases |
Reautorización/cerramiento en la vida

30.5 Glosario

|** | |... | TEN Autorización | Aceptación oficial del riesgo residual definido para un sistema o controles comunes. | tención Autorización límite | Conjunto de elementos del sistema incluidos en la decisión de riesgo. | | Baseline | Inicio de control set. | Control común | Control implementado para múltiples sistemas. – Mejora del control | Requisitos adicionales o más fuertes asociados con un control de base. tención de la herencia de control Silencioso en un control aplicable implementado por otro proveedor. Parámetro de control | Valor asignado a la Organización dentro de un control. | CPRT ANTE NIST Cybersecurity and Privacy Reference Tool. | El impacto del sistema de alta agua tención tiene precedencia sobre otros objetivos de información/seguridad aplicables, sujetos al análisis aprobado. | Silencioso OSCAL | Controles de Seguridad Abierto Evaluación Idioma. – POA plagaM | Plan de acción y hitos para debilidades, con acciones correctivas. | | Riesgo residual | El riesgo permanece después de controles y tratamiento. | | RMF | Marco de Gestión de Riesgos. – Clasificación de seguridad | Potential-impact determination for confidentiality, integrity, and availability. tención Plan de Seguridad del Sistema Silencioso Descripción del sistema y la implementación del control. TEN Tailoring | Ajuste basado en el riesgo y especificación de un conjunto de control inicial.

30.6 Subject index

Subjeto** |... | | ANTERIOR ANTERIOR 10, 16-17 | Silencioso Autorización tención Bases de referencia/tailoring | 13 | Silencioso | Controles comunes | Silenciosas familias de control Silencioso para la aplicación Silencioso analista junior Silencioso Silencioso Silencioso de vigilancia Silencioso OSCAL | ANTERIOR ANTERIOR 17, 30 | confidencialidad | 24 | Silencioso Liberación 5.2.0 Papeles en la vida cotidiana Silencioso Selección | 8 | Silencioso límite del sistema Ø Herramientas para prevenir la muerte

30.7 Referencias oficiales

- [Se indica] (<https://csrc.nist.gov/projects/risk-management>)
- [indicau]NIST SP 800-37 Rev. 2 obtenidos/u
fiel](<https://csrc.nist.gov/pubs/sp/800/37/r2/final>)
- [] [] [] [] [] []
- [indicau]NIST SP 800-53A Rev. 5 y Release 5.2.0 interpretado/u
fiel](<https://csrc.nist.gov/pubs/sp/800/53/a/r5/final>)
- []u contactos/u contacto](<https://csrc.nist.gov/pubs/sp/800/53/b/upd1/final>)
- [] [] [] [] [] []
- [] (<https://csrc.nist.gov/pubs/sp/800/18/r2/final>)

- [indicau]NIST SP 800-30 Rev. 1 buscado/u contacto](https://csrc.nist.gov/pubs/sp/800/30/r1/final)
- []](https://csrc.nist.gov/pubs/sp/800/39/final)
- []](https://csrc.nist.gov/projects/cprt/catalog)
- []](https://pages.nist.gov/OSCAL/)
- [indicau]NIST SP 800-53 controles descargas efectuadas/u contacto](https://csrc.nist.gov/projects/risk-management/sp800-53-controls/downloads)
- []] [cursos de introducción de XNIST RMF](#)

tención **Recordaje final:** Comunicados NIST, bases de referencia, parámetros, superposiciones, sistemas, amenazas, leyes, contratos, herramientas y cambio de riesgo organizativo. Confirme la fuente oficial actual, la autoridad local y los requisitos aplicables antes de la implementación, evaluación o autorización. | |.